

PESU Center for
Information Security,
Forensics and
Cyber Resilience



Welcome to

PES University

Ring Road Campus, EC Campus
Bengaluru



PESU Center for
Information Security,
Forensics and
Cyber Resilience



Information Security

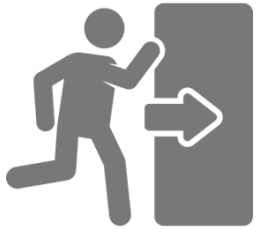
UE23CS343BB6

Prasad Honnavalli

Preet Kanwal

Dr. Vinodha

Unit 4, Lecture 5,



Emergency Exit



Assembly Point



Washroom



No Chatting



Phones on silent



No Sleeping

A Note on Security

- In this course, you will be exposed to information about security problems and vulnerabilities with computing systems and networks.
- To be clear, you are not to use this or any other similar information to test the security of, break into, compromise, or otherwise attack, any system or network without the express consent of the owner.
- In particular, you will comply with all my instructions when doing the labs.
  - My instructions are in consonance with applicable laws of India and PES University policies.
  - If in any doubt, please consult your professor!
- Any violation is at **YOUR RISK!**
  And may result in severe consequences.

Disclaimer

- ☞ *This presentation is purely educational.*
- ☞ *The views expressed by the presenter is not representation of any organization.*
- ☞ *The views are based on professional experience of the presenter and no liability is accepted by the presenter in the event of any potential or perceived losses resulting from this presentation.*

Apple: Safety vs Security

Engineering, Ethics, and Real-World Trade-offs

Learning Objectives

By the end of this session, students will be able to:

1. **Understand evolving responsibilities to customers** in the digital age, particularly how emerging technologies create new challenges for protecting user data and trust.
2. **Analyze tensions between customer privacy and societal obligations**, especially in contexts such as public safety and government access to data.
3. **Identify and evaluate potential harms** arising from technology design and deployment, and the role of managers in preventing or mitigating these harms.
4. **Assess strategies for reconciling competing responsibilities**, and develop reasoned approaches for decision-making in a global context.

Learning Objectives Mapped to Bloom's Taxonomy

Learning Objective	Bloom's Level	Justification
Understand evolving responsibilities to customers in the digital age	Understand (Level 2)	Students interpret how technology changes responsibilities; focus is on comprehension, not yet judgment
Analyze tensions between customer privacy and societal obligations	Analyze (Level 4)	Requires breaking down competing interests (privacy vs security) and examining relationships
Identify and evaluate potential harms and managerial responsibilities	Evaluate (Level 5)	Students must make judgments about risks, impacts, and responsibility
Assess strategies to reconcile competing responsibilities in a global context	Create (Level 6) (or Evaluate → Create bridge)	Involves synthesizing solutions and proposing approaches under constraints

This is not just a phone !

It’s a secure system designed to resist even its creator.

The Chain of Events

Dec 2, 2015	San Bernardino attack — 14 killed. Syed Farook identified as shooter.
Dec 3, 2015	FBI recovers Farook's iPhone 5C. It is locked with a PIN.
Feb 9, 2016	FBI asks Apple to create a backdoor tool — '**GovtOS**'.
Feb 16, 2016	Apple CEO Tim Cook publishes open letter: **WE REFUSE**.
Mar 28, 2016	FBI drops the case — a third party cracked the phone.
Result	Phone contained NO useful intelligence. Precedent: never set.



What is Privacy?

Consider a few prominent viewpoints on privacy that have served to define privacy in different ways.

Privacy

- Privacy is control over information flows. Not secrecy. Not hiding.
  - Unauthorized access (hackers)
  - Insider misuse (companies/employees)
  - Government overreach
  - Data aggregation (profiling)

- Who accesses data?
- Under what conditions?
- With what guarantees?

Privacy Example:

Messaging - Even with **end-to-end encryption**:

•Metadata is still exposed: IP addresses, timing, communication patterns

- ☞ Signal minimizes metadata, WhatsApp collects more metadata

- ☞ Content vs Metadata
- ☞ Metadata reveals relationships
- ☞ Often more dangerous than content

Location

- ☞ Location = behavioral pattern
- ☞ Home + work = identity
- ☞ Anonymization often fails

Biometrics

- ☞ Cannot be changed
- ☞ Permanent identifiers
- ☞ High risk if compromised

Privacy Threat Model

- External attackers
- Insider misuse
- Government overreach
- Data aggregation

Privacy Threat Model

Backdoor Principle

- If a system can be broken for good, It can be broken for bad!!!
- No controlled backdoors

Design Issues

- Design a private messaging system with encryption, auth, storage, metadata

Constraint

- Add lawful access requirement
- Modify your architecture

Insight

- Privacy failures are design failures
- Trust is not a control
- Architecture determines outcomes

Attack Checklist

- Key extraction?
- Metadata leakage?
- Backdoor misuse?
- Scalability risks?

Security vs Privacy

- Can we build systems that are secure **AND** selectively accessible? Do we need both?

- Security = mechanisms (crypto, auth)
- Privacy = outcome (user control)
- Security can exist without privacy. (CCTV)
- Can Privacy exist without Security?

Possible Harms

Alan Westin's Four States of Privacy

- **Solitude**—the individual stands by themselves, separate from the group and remains free from the observations of others;
- **Intimacy**—the individual is part of a small unit, wherein trust, information sharing and the rules of secrecy are negotiated with members of the unit;
- **Anonymity**—while the individual is in public, they still maintain freedom from identification and surveillance; (e.g. author writing under a pseudonym)
- **Reserve**—while the individual is in a large group, they maintain the ability to withhold communication or disengage from others to create a psychological barrier against unwanted intrusion.

These four states can be used to characterize individual expectations of privacy and how IT works to achieve or conflict with those expectations.

Helen Nissenbaum's Contextual Integrity

Privacy can be expressed as norms that should govern information access.

- **Norms are domain specific**; for example, the norms governing banking information will differ from the norms governing medical information.
- In addition, **norms are context specific**, such that each individual can have their own reasons for controlling access to their information in specific situations based on their own expectations, which govern those situations.
- This viewpoint presents a challenge to IT professionals:
  - *how to identify relevant norms and preserve norms when they introduce new or changing technology?*

Daniel Solove's Taxonomy of Privacy

- Privacy is understood by the activities and mechanisms that violate privacy as described in court proceedings.

- This includes activities such as **interrogation and surveillance** to **compel information disclosure**, secondary use and **appropriation or distortion**, especially of another's image.

- These activities can be used to determine when IT enables privacy-threatening outcomes.

Ryan Calo's Harm Dimensions

- **Objective harms are measurable and observable**, wherein a person's privacy has been violated and a direct harm is known to exist.
- **Subjective harms exist without an observable or measurable harm**, but where an expectation of harm exists.
  - Subjective harms may have the same impact on individual privacy because the individual takes similar steps to protect themselves.
- For IT professionals, the challenge is to recognize that the perception of harm is just as likely to have a significantly negative impact on individual privacy as experienced harms.
  - *Thus, IT professionals may need to rely on privacy notice and privacy controls to build and retain trust from individuals.*

The issues

- Managing harms to third parties
  - – i.e., parties with whom the company does not transact commercially or have direct contractual relations.

- Student to learn, apply, and develop skills to,
  1) Identify relevant harms,
  2) Determine responsibility for them,
  3) Develop appropriate responses, and
  4) Recognize political limits on what companies ought to do.

Identifying Harms

- Personal Privacy
  - Lack of privacy may be harmful in a psychological sense, with specific disclosures of private information causing emotional harm (Cambridge Analytica - personal information from tens of millions of Facebook users was harvested without consent and used for political advertising)
- Societal Harms
  - Part of what makes a society a good place in which to live is the extent to which it allows people freedom from the intrusiveness of others (**fear of surveillance changes behavior at scale)**
- A Right to Privacy

Identifying Harms

- ☞ Am I comfortable with the likely causes of this action?
  - Visibility – am I comfortable if this were on the front page of the new paper?
  - Legacy - Is this how I want to. be remembered?
- ☞ Am meeting my duties and respecting others' rights?
  - Fiduciary, property, reliability, transparency, Diggnity, Fairness, etc.
  - **No rights are ABSOLUTE!**
- ☞ Am I respecting the community and its norms?
  - No one size fit all approach

Determining Responsibility

- Culpability
  - The focus often turns to harms that a company has directly caused through its actions (e.g., environmental pollution, contaminated food/medicines)

- Complicity
  - Complicity in the harm for which another party can be considered culpable.
  - Debatable
  - Full spectrum from “silent complicity” to “aiding and abetting”

- Capability
  - Responsible for harm arises from their capability to help prevent harms to third parties that are not caused by a company’s activities
  - Prevent severity of the harm and the ease with which it can be prevented

Why Snowden matters?



Why Snowden Matters

- Revealed real-world mass surveillance capabilities
- Shifted privacy from theory to engineering reality
- Demonstrated scale: millions of users affected

- NSA program collecting data from major tech companies
- Access to emails, chats, videos, stored files
- Centralized access to user data at scale

Upstream Collection — What It Was

- Interception of internet traffic at backbone level
- Tapping fiber optic cables and infrastructure
- Bulk collection, not targeted surveillance

- Privacy can be violated during transmission
- Encryption (TLS) is critical but not sufficient
- Metadata remains visible even if content is encrypted
  - Who you called
  - When the call happened
  - Duration and frequency

Metadata — Why It Matters

- Metadata is highly revealing
- Reveals relationships and social networks
- Builds detailed behavioral profiles
- Often more powerful than content itself

"Would you rather I read your messages… or just analyze your metadata?"

Metadata vs Data: Why Metadata Matters More

- Content = What you said (messages, emails, calls-audio,video)
  - Example: *"Let's meet at 5". (but no context)*

- Metadata reveals what you do—and who you are = Who, when, where, how often
  - Repeated late-night calls from hospital

- Metadata reveals patterns, relationships, and behavior
  - **Reveals patterns** → routines, habits, behavior
  - **Builds social graphs** → relationships, influence
  - **Enables inference** → health, legal, personal life
  - **Scales easily** → ideal for mass surveillance
  - **De-anonymizes users** → identity from patterns

Metadata vs Data: Why Metadata Matters More

- Even with encryption, metadata is exposed
- Privacy fails if metadata is ignored
- Key insight: Metadata defines you more than content

iOS Secure Enclave

Apple case study/ios_secure_enclave_handout.pdf

What the FBI Actually Asked For (GovtOS)

- Disable the 10-attempt auto-erase: after 10 wrong PINs, iPhone wipes itself
- Remove the progressive delay between PIN attempts (currently up to 1 hour between tries)
- Allow brute-force via external interface — USB / Bluetooth rather than on-screen tapping
- Apple was NOT asked to 'crack' the phone — they were asked to BUILD A NEW TOOL
- A 4-digit PIN = 10,000 combinations. With no delay/wipe: crackable in minutes
- Key legal instrument: All Writs Act of 1789 — the FBI's legal basis for the order

iOS Security Architecture — Why It's Hard to Break

Secure Enclave

Isolated co-processor. Stores encryption keys. Never exposed to iOS or apps.

Hardware Entanglement

Keys are fused with device-specific UID burned at manufacture — unextractable.

Key Derivation (PBKDF2)

Your PIN + UID → 256-bit AES key. 80ms delay is hardware-enforced, not software.

Effaceable Storage

10-attempt wipe deletes the key, not the data. Data becomes crypto-garbage instantly.

The Core Technical Argument

Apple's Position

- A backdoor, once built, cannot be 'used once only'
- GovtOS would become a master key — theft risk is enormous
- Cannot write code that only runs for one government
- China, Russia, others will demand the same via local courts
- Weakening security for criminals weakens it for all users
- Sets precedent: 1,300+ phones already awaiting similar orders

FBI's Position

- This is one phone, one dead terrorist, one case
- Apple already assists in iCloud backups — why not this?
- Encryption should not create 'warrant-proof' spaces
- Congress has not yet legislated on this — courts must fill the gap
- Public safety outweighs corporate privacy concerns
- Apple has the technical capability — it's a choice, not impossibility

“Can you build a system that is secure… but selectively breakable?”

"Can you write software that only runs once,
for one specific person,
and then disappears forever?"

Think as engineers.

We believe security shouldn’t come at the expense of individual privacy.

https://www.apple.com/in/privacy/government-information-requests/

Your Role

Role Play and Questions

What Should the Law Say? — Open Discussion

- Should governments be able to mandate encryption backdoors by law?
- Who should decide — courts, legislatures, engineers, or users?
- Is there a technical middle ground? (Key escrow? CSAM scanning? Hardware-level access?)
- India's IT Act & upcoming DPDP Act — how does India's framework compare?
- The 'Going Dark' problem: as encryption spreads, does lawful surveillance become impossible?
- If Apple complied — which governments globally would get the same access?

Discussions - Introduction

- *First, what are Apple's responsibilities in the area of safety and security and how do new technologies complicate them?*

- *Second, are there tensions between these and other responsibilities to customers, employees and investors?*

- *Third, how should business leaders reconcile these potential tensions in a global context?"*

The FBI wanted to:

- Prevent the phone from erasing itself
  - If certain security settings are enabled, an iPhone can wipe personal data after 10 failed attempts to unlock the phone by entering a password.
  - This is something that the FBI did not want to happen on Farook's phone.
- Automate the process of trying out different passcode combinations
  - Farook used a four-digit passcode that had 10,000 different possible combinations.
  - The FBI didn't want to guess them all manually, so it wanted Apple to let them try the passcode electronically.
  - This means that the FBI could simply tell a computer to test each passcode, which would take minutes, if not seconds.

The FBI wanted to:

- Without unnecessary delay
  - Each time you input a passcode incorrectly, the iPhone restricts you from doing so for longer and longer periods.
  - The FBI wanted this major obstacle removed.
- Control the procedure, but does not know how it's done
  - This is an intriguing line because it implies that the FBI is willing to let Apple work on the iPhone at its headquarters in a way that it doesn't expose the encryption software to the public.
  - The FBI argued that the SIF will only work on Farook's phone and will be known only to Apple, who could choose to destroy it, as this case moved through courts.

Arguments put forth by Apple

- Apple and its supporters, which included prominent internet giants like Google and Facebook, argued on numerous fronts that the court decision endangered everyone's privacy.
- Firstly, Apple claimed that the court order effectively forced the firm to develop a code, infringing on the firm's First Amendment right to free speech by compelling it to "say" something it didn't want to say.
  - Computer code had already been established as legally protected speech in previous court cases.
- Secondly, once constructed, such a backdoor could slip into the wrong hands, threatening the privacy of all iPhone users.
- Finally, it would set a dangerous precedent; law enforcement bodies could repeatedly require businesses such as Apple to assist in criminal investigations, effectively making technology companies an agent of the government.

Arguments in support of Apple

- Apple's supporters in the technology industry, eager to protect their reputations above security, were backing the iPhone maker.
- Whatsapp's creator, Jan Koum, who is now the CEO of Facebook, wrote:
  - *"We must not allow this dangerous precedent to be set. Today our freedom and our liberty are at stake."*
- The Information Technology Industry Council, which represents Google, Facebook, Microsoft, Samsung, Blackberry, and plenty of other companies, released the following statement:
  - *"Our fight against terrorism is sought strengthened by the security tools and technologies created by the technology sector, so we must tread carefully given our shared goals of improving security, instead of creating insecurity."*

Arguments in support of Apple

- Google chief executive, Sundar Pichai said: *"Forcing companies to enable hacking could compromise users' privacy."*
- Edward Snowden, whose allegations about US government spying, provoked Apple's stance on password-protected data, said that the FBI was "*creating a world where citizens rely on Apple to defend their rights, rather than the other way around".*
- The United Nations Human Rights Chief expressed his dissatisfaction with the FBI order, stating the possibility of *"the potential for extremely damaging implications"* on human rights, journalists, whistleblowers, political dissidents, and others.
  - He argued, an order like this is *"potentially a gift to authoritarian regimes."*

Who was backing the FBI

- According to Jonathan Thompson, executive director of the National Sheriff's Association, Apple's failure to cooperate with FBI directives, places "profit over safety." He went on to say, "this has nothing to do with privacy; it's all about money and their brand." The federal government claims to be worried about national security. He further argued that encryption made it more difficult for the FBI to solve crimes and prevent terrorist attacks.
- White House press secretary Josh Earnest said to the reporters that the FBI was "simply asking for something that would have an impact on this one device". He said that the FBI had the White House's full support in the case.
- Donald Trump stated that he "100% agrees with the judges." He told Fox News, "We should open it up."

Who was backing the FBI

- While much of the technological world has backed Apple's position, other analysts believed that the company was misrepresenting the debate.
- "The truth is that there is a protection in place: a warrant," writer Jack Smith argued on mic.com.
- "We should fight to make warrants difficult to obtain. But the real unprecedented feat is the idea that a corporation like Apple should be able to prevent our law enforcement from carrying out a lawfully obtained warrant."
- According to the family of the killed Fusilier Lee Rigby in the United Kingdom, Apple was "protecting a murderer's privacy at the expense of public safety.

Should Apple Unlock the iPhone?

Yes

- Market share
- Legal order
- A confined case
- Privacy not absolute
- Prevent terrorism
- Civic duty

No

- Employees' interests
- Economic burden
- Cybersecurity
- Legal Precedent
- Not a finite case
- Other means of access
- Global implications
- Trust of the government
- Personal conviction

Should Apple Unlock the iPhone?

- Clarifying Legal Issues
  - *"Is ordering Apple to re-engineer their software different from asking Apple to provide information that it already can access*

- Clarifying Backdoor access*?"*
  - *Think Huawei ?*

What Are Apple's Responsibilities for Public safety?

Is Apple responsible to fight terrorism? Or simply not assist in terrorism?
Is Apple responsible for how people use its devices?
Do IT tec firms have additional responsibilities?

Minimal

- User responsibility
- Already obeyed order
- Other means of access
- Why single out Apple?
- Government responsibility

Extensive

- A void aiding crime, terrorism
- Prevent/solve crime, terrorism
- Technical ability
- Protect society
- Trust the government

What Are Apple's Responsibilities for its customers Privacy?

Is right to privacy universal?
Who is responsible for upholding the right to privacy?

Minimal

- Right is against government intrusion
- Caveat emptor
- Depends on societal harm
- iCloud example

Extensive

- Privacy as universal right
- Apple is entrusted by users
- Harms to users
- Value proposition of iPhone
- Protect customers globally

Is Apple Delivering Its Responsibilities?

Yes

- Respect for local laws
- Maintaining Market share in China
- Supporting public safety

No

- Continued threats to public safety
- Complicit in potential violation of users' privacy in China

Assignment: Privacy Versus Safety?

- If a “backdoor” is created:
  - How do you prevent misuse?
  - Can it be limited to one device?
  - What are the attack surfaces?

- List your assets, adversaries and abuse case.
- Create a threat model for the “backdoor” using STRIDE.

Thank you!

Follow us

isfcr.pesu

www.isfcr.pes.edu

ISFCR

PESU ISFCR

PESU Center for Information Security, Forensics and Cyber Resilience

PES UNIVERSITY